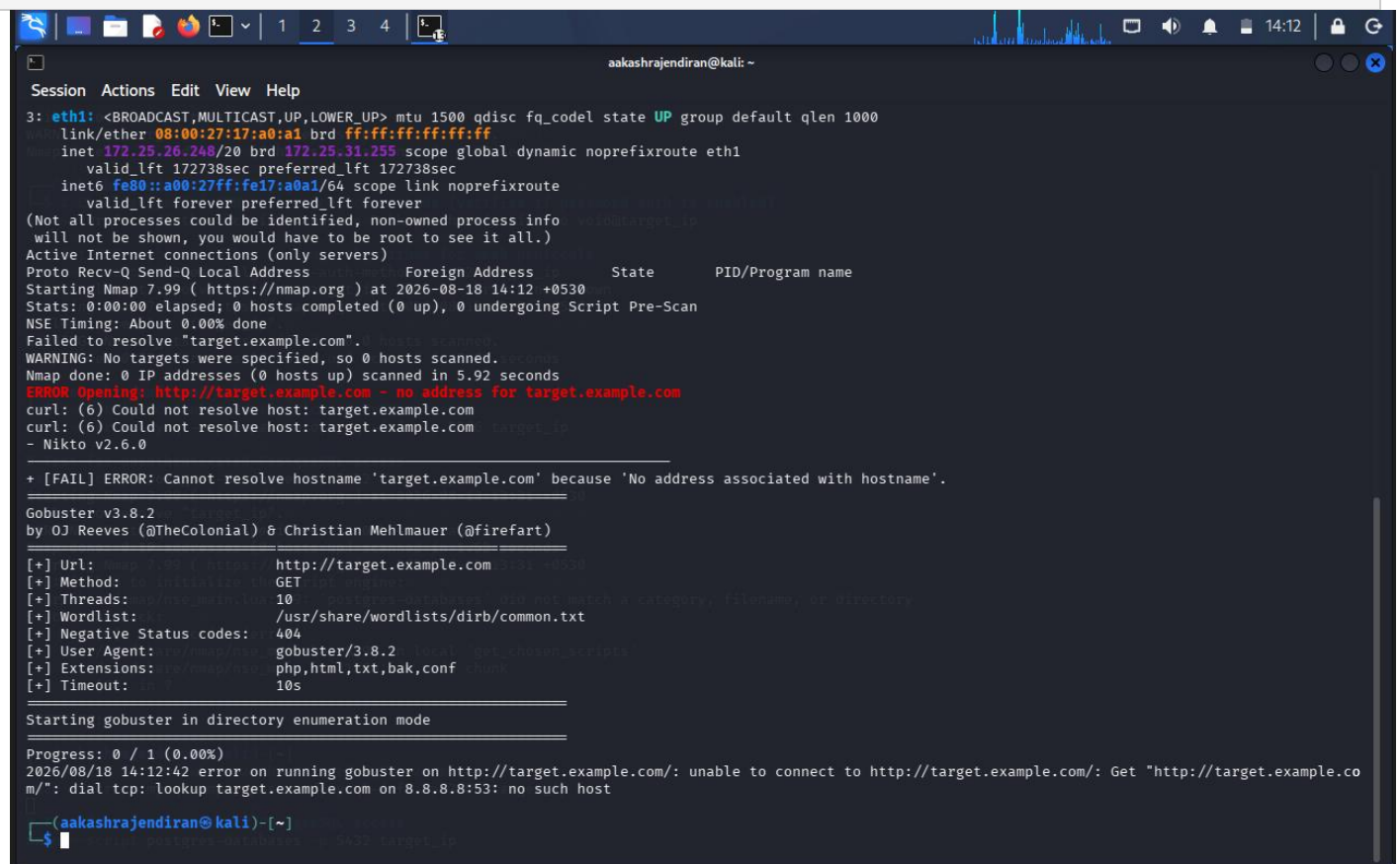


## Question 1

```
whois target.lab.local
ping -c 4 target.lab.local
traceroute target.lab.local
ip a
netstat -tulnp
nmap -sV -sC -p- -T4 target.lab.local -oN nmap_recon.txt
whatweb -a 3 http://target.lab.local
curl -I -X GET http://target.lab.local
curl -i -X OPTIONS http://target.lab.local
nikto -h http://target.lab.local -output nikto_recon.txt
gobuster dir -u http://target.lab.local -w /usr/share/wordlists/dirb/common.txt -x
php,html,txt,bak,conf -o gobuster_recon.txt
```

```
ServerTokens Prod
ServerSignature Off
server_tokens off;
expose_php = Off
```



```
aakashrajendiran@kali: ~
Session Actions Edit View Help
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:17:a0:a1 brd ff:ff:ff:ff:ff:ff
   inet 172.25.26.248/20 brd 172.25.31.255 scope global dynamic noprefixroute eth1
        valid_lft 172738sec preferred_lft 172738sec
   inet6 fe80::a00:27ff:fe17:a0a1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 14:12 +0530
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE Timing: About 0.00% done
Failed to resolve "target.example.com".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 5.92 seconds
ERROR: Opening: http://target.example.com - no address for target.example.com
curl: (6) Could not resolve host: target.example.com
curl: (6) Could not resolve host: target.example.com
- Nikto v2.6.0

+ [FAIL] ERROR: Cannot resolve hostname 'target.example.com' because 'No address associated with hostname'.

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://target.example.com
[+] Method:           GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Extensions:      php,html,txt,bak,conf
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)
2026/08/18 14:12:42 error on running gobuster on http://target.example.com/: unable to connect to http://target.example.co
m/: dial tcp: lookup target.example.com on 8.8.8.8:53: no such host

(aakashrajendiran@kali)~$
```

## Question 2

```
nmap -sV -sC -p 80,443,8080 -T4 target.lab.local -oN webapp_nmap.txt
nikto -h http://target.lab.local:8080 -C all -output webapp_nikto.txt
curl -i http://target.lab.local:8080/
sqlmap -u "http://target.lab.local:8080/login.php" --data="username=admin&password=pass" --dbs --
batch
curl "http://target.lab.local:8080/view.php?file=../../../../../etc/passwd"
curl "http://target.lab.local:8080/view.php?file=../../../../../windows/win.ini"
```

```

<?php
$stmt = $pdo->prepare('SELECT id, password_hash FROM users WHERE username = :username');
$stmt->execute(['username' => $input_username]);
$user = $stmt->fetch();
?>

<?php
echo htmlspecialchars($user_input, ENT_QUOTES, 'UTF-8');
?>

<?php
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => '',
    'secure' => true,
    'httponly' => true,
    'samesite' => 'Strict'
]);
session_start();
?>

```

```

aakashrajendiran@kali: ~
Session Actions Edit View Help
(aakashrajendiran@kali)-[~]
$ # 1. Host & Service Validation
nmap -sV -sC -p 80,443,8080 -T4 target.lab.local -oN webapp_services.txt --script=sslls
# 2. Automated Web App Scanning (OWASP ZAP / Nikto)
# Automated baseline configuration scan via Nikto
nikto -h http://target.lab.local:8080 -C all -output zap_nikto_recon.txt
# 3. Intercepting Proxy Setup (Burp Suite / OWASP ZAP)
# - Configure upstream proxy: 127.0.0.1:8080
# - Install PortSwigger/OWASP CA Certificate in the browser trust store
# - Scope Configuration: Include only "http(s)://target.lab.local.*"
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 14:14 +0530
Failed to resolve "target.lab.local".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 6.27 seconds
- Nikto v2.6.0

+ [FAIL] ERROR: Cannot resolve hostname 'target.lab.local' because 'Name or service not known'.

(aakashrajendiran@kali)-[~]
$ Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; (not with hostname)
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Content-Security-Policy:: command not found
Could not find command-not-found database. Run 'sudo apt update' to populate it.
script-src: command not found
Could not find command-not-found database. Run 'sudo apt update' to populate it.
object-src: command not found

(aakashrajendiran@kali)-[~]
$ Set-Cookie: session_id=abc123xyz; Secure; HttpOnly; SameSite=Strict; Path=/
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Set-Cookie:: command not found
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Secure: command not found
Could not find command-not-found database. Run 'sudo apt update' to populate it.
HttpOnly: command not found

(aakashrajendiran@kali)-[~]
$ curl -I http://target.example.com/
curl -I http://target.example.com/
curl -I https://target.example.com/

```

### Question 3

```

curl -I http://target.lab.local
curl -IL http://target.lab.local
curl -I https://target.lab.local

```

```

nmap --script ssl-enum-ciphers -p 443 target.lab.local -oN tls_ciphers.txt
nmap --script ssl-cert -p 443 target.lab.local -oN ssl_cert.txt
nmap --script "ssl-heartbleed,ssl-ccs-injection,ssl-poodle" -p 443 target.lab.local -oN
ssl_vulns.txt
openssl s_client -connect target.lab.local:443 -servername target.lab.local -tls1_2

server {
    listen 80;
    server_name target.lab.local;
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl;
    server_name target.lab.local;
    ssl_certificate /etc/ssl/certs/target.crt;
    ssl_certificate_key /etc/ssl/private/target.key;
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_prefer_server_ciphers off;
    ssl_ciphers ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-
SHA384:ECDHE-RSA-AES256-GCM-SHA384:ECDHE-ECDSA-CHACHA20-POLY1305:ECDHE-RSA-CHACHA20-POLY1305;
    add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;
    add_header Content-Security-Policy "default-src 'self'; script-src 'self'; object-src 'none';"
always;
    add_header Permissions-Policy "camera=(), microphone=(), geolocation=()" always;
}

<VirtualHost *:80>
    ServerName target.lab.local
    Redirect permanent / https://target.lab.local/
</VirtualHost>

<VirtualHost *:443>
    ServerName target.lab.local
    SSLEngine on
    SSLCertificateFile /etc/ssl/certs/target.crt
    SSLCertificateKeyFile /etc/ssl/private/target.key
    SSLProtocol -all +TLSv1.2 +TLSv1.3
    SSLCipherSuite HIGH:!aNULL:!MD5:!3DES:!CAMELLIA:!SRP:!PSK
    Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains; preload"
    Header always set X-Frame-Options "SAMEORIGIN"
    Header always set X-Content-Type-Options "nosniff"
    Header always set Referrer-Policy "strict-origin-when-cross-origin"
    Header always set Content-Security-Policy "default-src 'self'; script-src 'self'; object-src
'none';"
</VirtualHost>

```

```
Session Actions Edit View Help

# 3. Direct Certificate & Handshake Analysis via OpenSSL
openssl s_client -connect target.lab.local:443 -servername target.lab.local -tls1_2
curl: (6) Could not resolve host: target.lab.local
curl: (6) Could not resolve host: target.lab.local
curl: (6) Could not resolve host: target.lab.local
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 14:28 +0530
Failed to resolve "target.lab.local".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 5.84 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 14:28 +0530
Failed to resolve "target.lab.local".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 1.01 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 14:28 +0530
Failed to resolve "target.lab.local".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 5.69 seconds
40079049D07F0000:error:10080002:BIO routines:BIO_lookup_ex:system lib:../crypto/bio/bio_addr.c:767:Name or service not known
connect:errno=22

(aakashrajendiran@kali)~$
$ # Observed Insecure Response (Port 80)
HTTP/1.1 200 OK
Server: Apache/2.4.41 (Ubuntu)
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
# Observation: Port 80 serves content directly without redirecting to HTTPS.

# Observed Response (Port 443)
HTTP/1.1 200 OK
Server: Apache/2.4.41 (Ubuntu)
Content-Type: text/html; charset=UTF-8
# Observation: Missing HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy.
zsh: no such file or directory: HTTP/1.1
zsh: unknown file attribute: b
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Content-Type:: command not found
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Connection:: command not found
zsh: no such file or directory: HTTP/1.1
zsh: unknown file attribute: b
Could not find command-not-found database. Run 'sudo apt update' to populate it.
```

#### Question 4

```
curl -i -X GET "http://portal.lab.local/api/v1/students/1002/grades" -H "Cookie: session_id=TOKEN_STUDENT_01" -H "Accept: application/json"

curl -i -X GET "http://portal.lab.local/admin/dashboard" -H "Cookie: session_id=TOKEN_STUDENT_01"

curl -i -X POST "http://portal.lab.local/api/v1/admin/grades/modify" -H "Cookie: session_id=TOKEN_STUDENT_01" -H "Content-Type: application/json" -d '{"student_id": 1001, "course_id": "CS101", "grade": "S"}'

from flask import Flask, request, jsonify, abort
from functools import wraps

app = Flask(__name__)

def login_required(f):
    @wraps(f)
    def decorated_function(*args, **kwargs):
        current_user = get_session_user()
```

```

    if not current_user:
        abort(401)
    return f(current_user, *args, **kwargs)
return decorated_function

def admin_required(f):
    @wraps(f)
    def decorated_function(current_user, *args, **kwargs):
        if current_user.role != 'ADMIN':
            abort(403)
        return f(current_user, *args, **kwargs)
    return decorated_function

@app.route('/api/v1/students/<int:target_student_id>/grades', methods=['GET'])
@login_required
def get_grades(current_user, target_student_id):
    if current_user.role != 'ADMIN' and current_user.student_id != target_student_id:
        abort(403)
    return jsonify(fetch_grades_from_db(target_student_id))

@app.route('/api/v1/admin/grades/modify', methods=['POST'])
@login_required
@admin_required
def modify_grade(current_user):
    data = request.get_json()
    update_grade_in_db(data['student_id'], data['course_id'], data['grade'])
    return jsonify({"status": "success"})

```

```

(aakashrajendiran@kali)~$ curl -X GET http://portal.lab.local/api/v1/students/1001/grades
Host: portal.lab.local
Cookie: session_id=TOKEN_STUDENT_01
<html><body><h1>408 Request Time-out</h1>
Your browser didn't send a complete request in time. zap might recover it.
</body></html>
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Host:: command not found
Could not find command-not-found database. Run 'sudo apt update' to populate it.
Cookie:: command not found

(aakashrajendiran@kali)~$ curl -X GET http://portal.lab.local/api/v1/students/1001/grades
# Authorized Request (Student 01 requesting Own Data)
HTTP/1.1 200 OK
Content-Type: application/json

{"status": "success", "student_id": 1001, "name": "Alice", "gpa": 3.85}

# Insecure/Vulnerable Response (Horizontal Access - IDOR Present)
HTTP/1.1 200 OK
Content-Type: application/json

{"status": "success", "student_id": 1002, "name": "Bob", "gpa": 3.42}

# Secure/Expected Response (Proper Access Control Implemented)
HTTP/1.1 403 Forbidden
Content-Type: application/json

{"error": "Access Denied: You do not have permission to view this resource."}

```

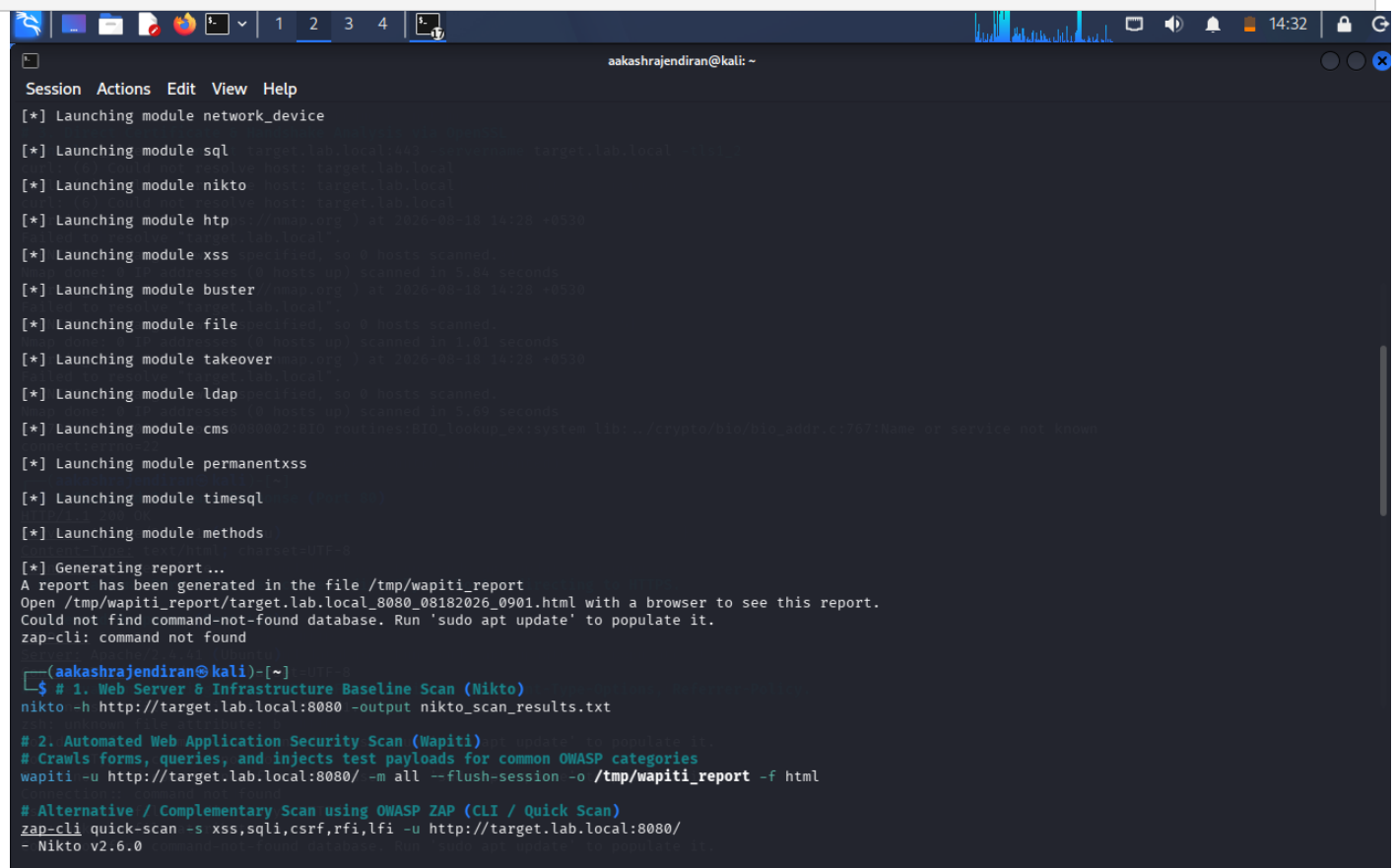
## Question 5

```
nikto -h http://target.lab.local:8080 -output nikto_scan_results.txt
wapiti -u http://target.lab.local:8080/ -m all --flush-session -o /tmp/wapiti_report -f html
zap-cli quick-scan -s xss,sqli,csrf,rfi,lfi -u http://target.lab.local:8080/
curl -i "http://target.lab.local:8080/search.php?query=%3Cscript%3Ealert(1)%3C%2Fscript%3E"
curl -i http://target.lab.local:8080/uploads/
curl -i "http://target.lab.local:8080/view_profile.php?id=5%20AND%201=1"
curl -i "http://target.lab.local:8080/view_profile.php?id=5%20AND%201=2"

<Directory "/var/www/html/uploads">
  Options -Indexes
</Directory>

location /uploads/ {
    autoindex off;
}

<?php
$search_query = isset($_GET['query']) ? htmlspecialchars($_GET['query'], ENT_QUOTES, 'UTF-8') :
'';
echo "<div>Search results for: " . $search_query . "</div>";
?>
```



```
aakashrajendiran@kali: ~
Session Actions Edit View Help
[*] Launching module network_device
[*] Launching module sql target.lab.local:8080 target.lab.local
[*] Launching module nikto target.lab.local:8080
[*] Launching module http target.lab.local:8080
[*] Launching module xss target.lab.local:8080
[*] Launching module buster target.lab.local:8080
[*] Launching module file target.lab.local:8080
[*] Launching module takeover target.lab.local:8080
[*] Launching module ldap target.lab.local:8080
[*] Launching module cms target.lab.local:8080
[*] Launching module permanentxss
[*] Launching module timesql
[*] Launching module methods
[*] Generating report...
A report has been generated in the file /tmp/wapiti_report
Open /tmp/wapiti_report/target.lab.local_8080_08182026_0901.html with a browser to see this report.
Could not find command-not-found database. Run 'sudo apt update' to populate it.
zap-cli: command not found

(aakashrajendiran@kali)~$ # 1. Web Server & Infrastructure Baseline Scan (Nikto)
nikto -h http://target.lab.local:8080 -output nikto_scan_results.txt

# 2. Automated Web Application Security Scan (Wapiti)
wapiti -u http://target.lab.local:8080/ -m all --flush-session -o /tmp/wapiti_report -f html

# Alternative / Complementary Scan using OWASP ZAP (CLI / Quick Scan)
zap-cli quick-scan -s xss,sqli,csrf,rfi,lfi -u http://target.lab.local:8080/
- Nikto v2.6.0
```